VulnSuite

VulnSuite helps security teams understand where systems are exposed, investigate suspicious server activity and coordinate approved responses. It connects assessment findings with operational evidence while keeping responsibility, review and deployment requirements visible.

Assessment and detection

- Code, dependencies and infrastructure assessment
- Linux and Windows security telemetry
- Malware signals and cross-host correlation

Security operations

- Verified identity, roles and a shared SOC view
- Incident ownership and central agent enrollment
- Reviewed quarantine, isolation and cloud-WAF response

Introducing VulnSuite | Vulnerability assessment, server monitoring and approved security response.

What the suite addresses

Security teams need a clear path from identifying exposure to deciding what action is justified. VulnSuite supports that process by linking findings, suspicious activity and investigation records, helping analysts prioritise work and document their decisions.

Reduce exposure

- Find vulnerable software and unsafe configurations
- Assess exposed services, APIs and TLS settings
- Prioritise findings using severity and asset context

Investigate and respond

- Connect host alerts with vulnerability findings
- Assign incidents, review evidence and track action
- Approve bounded containment and inspect receipts

Selected detection signals support investigation; coverage is not equivalent to a complete EDR platform.

Platform coverage

Different assets expose different kinds of risk, from vulnerable libraries to unsafe infrastructure settings and suspicious host activity. VulnSuite brings assessment and monitoring into a common operational context, with coverage determined by configured tools and telemetry sources.

Assessment modules

- SCA, secrets and static code analysis
- Network, cloud, containers and asset discovery
- IaC, Kubernetes and external attack surface
- API testing and software supply-chain checks

Protection and operations

- Linux audit and Windows event adapters
- Access, process, malware and integrity signals
- SOC console, investigations and agent lifecycle
- Signed notifications and approved response plans

Assessment and protection services retain separate persistence and deployment boundaries.

Software and supply-chain risk

Applications inherit risk from their own code, third-party dependencies and build artifacts. These checks help teams understand what software contains, identify known weaknesses and retain supporting evidence so remediation and software release decisions can be reviewed.

Code and dependencies

- Trivy, pip-audit and OSV-Scanner collectors
- Semgrep and Bandit static analysis
- Gitleaks and TruffleHog secret detection

Build and artifact evidence

- Syft software bill of materials
- Cosign signature and attestation checks
- VEX statements captured in finding evidence
- Risk scoring and remediation lifecycle tracking

Coverage depends on configured targets, installed tools and available advisory data.

Infrastructure and API assessment

Exposed services, weak configurations and application interfaces can create paths into an organisation. Assessment collectors help identify these conditions across selected targets, giving teams evidence to prioritise fixes and confirm which systems need closer investigation.

Infrastructure

- Nmap service discovery and testssl.sh TLS checks
- Prowler cloud configuration collectors
- Checkov / Trivy IaC and Kubernetes posture checks

Applications and APIs

- Nuclei and OWASP ZAP assessment collectors
- Target allowlists and active-scan configuration gates
- External discovery with Subfinder and httpx

Assessment scans complement host monitoring and inline WAF enforcement.

Verified identity and access

Security operations involve sensitive evidence and actions that can interrupt services. Verified identity and explicit permissions establish who may view information or approve changes, while tenant boundaries limit assessment access to the organisation identified by trusted tokens.

Authentication and roles

- Verify token signature, issuer, audience and expiry
- Require signed tenant and explicit role claims
- Separate viewer, auditor, analyst and admin rights
- Sign-in and MFA follow identity-provider policy

Tenant and approval boundaries

- Bind assessment transactions to signed tenant ID
- Enforce PostgreSQL row-level security policies
- Bind protection access to one organisation
- Require a different admin to approve playbooks

JWT verification and RLS controls are implemented; live IdP integration and database-role enforcement need staging.

Unified operations console

An analyst investigating an alert needs to understand the affected host, its known weaknesses and any response already underway. The console brings that context together, helping teams coordinate investigation while making unavailable information visible.

Shared investigation view

- View intrusion alerts and vulnerability findings
- Inspect agent health, sensor status and version drift
- Create and assign incidents from selected alerts
- Review response plans before approval

Operational safeguards

- Apply the same API role checks to console actions
- Keep access tokens in browser-tab memory
- Report unavailable upstream sources explicitly
- Retrieve findings through a fixed HTTPS connector

The console shows bounded recent lists; it is not an exhaustive cross-platform evidence search.

Windows and Linux monitoring

Server monitoring depends on collecting useful activity from the operating system and making gaps visible. Windows event sources and Linux audit records provide investigation evidence, while sensor health indicators help teams distinguish quiet systems from missing telemetry.

Windows monitoring

- Security log authentication and network logons
- RDP and SMB evidence where source events support it
- Sysmon process-creation records
- Selected fields without raw command-line capture

Linux monitoring

- Event-driven audit execution records
- Linux /proc process polling
- SSH access, API denials and file-integrity signals
- Sensor health and missing-telemetry indicators

Windows and Linux support monitoring and approved containment. Native enforcement and recovery require staging validation.

Process and malware detection

Selected process patterns and reviewed malware indicators provide clues that warrant investigation. A known-bad hash match supplies specific file evidence; analysts can review its context before approving action, while missing scanners or telemetry remain visible as coverage limitations.

Suspicious activity

- Recognised web-server parent spawning a shell
- Execution from writable temporary locations
- Deleted executable signals on Linux
- Event records for short-lived processes

Malware evidence

- Known-bad SHA256 matches on selected targets
- Optional Linux selected-file ClamAV scans
- Path, signature and hash retained for review
- Unavailable scanners surface degraded coverage

Coverage excludes complete memory scanning and full-disk protection. File quarantine does not terminate a running process.

Lateral-movement signals

Activity that appears ordinary on one server can become suspicious when repeated across several hosts. Correlating authentication events helps analysts recognise possible account misuse or movement between systems, while retaining context needed to assess legitimate administrative activity.

Correlated patterns

- Password spraying across multiple hosts
- Same-user successful-login fan-out
- Suspected pivots from already flagged hosts
- Remote-access evidence from supported event sources

Investigation context

- Administrator-defined host-to-IP ownership
- Time-bounded correlation with retained evidence
- Retry, out-of-order and restart handling
- Expiring exceptions for reviewed false positives

NAT, shared accounts and legitimate automation need review; protocol labels require supporting source evidence.

WAF integration

Web application firewalls provide an enforcement point for traffic reaching protected applications. Connecting their signals with investigations helps teams understand attempted abuse and review scoped blocking decisions, with tuning and deployment checks needed to avoid disrupting legitimate requests.

On-premises or proxy WAF

- Nginx / ModSecurity and OWASP CRS templates
- Sanitised serial-JSON rule-match collection
- DetectionOnly starting configuration
- No request-body or credential export

Cloudflare response connector

- Use a configured zone and custom-ruleset scope
- Apply an approved source-IP block
- Embed fixed expiry in the provider rule
- Retry cleanup without extending the deadline

Rule ordering, provider permissions, propagation and real traffic enforcement remain staging checks.

Reviewed local containment

Containment can interrupt business services, so response decisions need clear evidence and accountability. VulnSuite places supported file quarantine and host isolation behind separate approval and local policy checks, with recorded outcomes and reviewed recovery paths.

Quarantine and restoration

- Use approved malware path and SHA256 evidence
- Linux: private same-filesystem quarantine vault
- Windows: file-handle checks and protected ACLs
- Restore without overwriting existing files

Isolation and release

- Require separate approval and local policy
- Linux: kernel-expiring nftables isolation
- Windows: firewall rules with local recovery tasks
- Keep configured management exceptions

Containment is disabled by default. Windows expiry uses local recovery tasks; Linux uses kernel timeouts.

How the components fit

The assessment service evaluates exposure; the protection service handles telemetry, investigations and response. Their separate responsibilities help teams plan access, storage, maintenance and integration around the requirements of each service.

Assessment service

- Scanner collectors and orchestration workers
- Canonical findings and deterministic risk scoring
- Verified API access and PostgreSQL tenant policies
- Read-only findings feed into the operations console

Protection service

- Authenticated Linux and Windows agents
- One organisation per SQLite operational store
- Detection, incidents, policies and response history
- Independent delivery and cloud-response worker

SQLite protection persistence is not a horizontally scalable or highly available PostgreSQL backend.

Central agent lifecycle

Host monitoring depends on knowing which agents are enrolled, authorised and reporting correctly. Central lifecycle controls help maintain that inventory, replace credentials, withdraw access and identify policy or version differences that require administrator attention.

Credential management

- Issue expiring, one-time enrollment credentials
- Store hashes of enrolled host credentials
- Rotate keys and revoke agent access centrally
- Cancel unexecuted responses after revocation

Inventory and policy

- Track platform, agent version and queue health
- Record administrator policy-version history
- Flag drift from the desired software version
- Keep privileged response enablement local to hosts

Agent software installation and upgrades use an administrator-controlled rollout.

Incident and notification workflows

Investigations often involve several people and external operational systems. Incident records preserve ownership and decisions, while signed notifications carry relevant information to organisation-operated integrations, helping teams coordinate work and recover delivery after temporary service failures.

Investigation workflow

- Link alerts to owned incident cases
- Track status, notes and evidence timelines
- Protect concurrent edits with case versions
- Review alerts and add scoped, expiring exceptions

SIEM and ticketing bridges

- Send signed JSON to fixed HTTPS endpoints
- Persist delivery state, leases and retry attempts
- Attach stable keys for receiver deduplication
- Audit outcomes without storing upstream secrets

Webhooks support organisation-operated adapters; native Jira, ServiceNow or Splunk connectors are not implied.

Reliable delivery and retention

Network interruptions and growing evidence volumes can affect security operations. Persistent queues and acknowledgement checks support recovery after outages, while backup and retention controls help teams manage stored evidence according to investigation needs and operational requirements.

Telemetry continuity

- Keep events until exact acknowledgement
- Replay retained events after service outages
- Pause collection visibly when the queue is full
- Archive older events without fresh containment

Evidence maintenance

- Create consistent SQLite backups and verify restore
- Preview retention cleanup before applying it
- Preserve incident and response-linked evidence
- Create offline-agent and stale-sensor alerts

Schedule maintenance explicitly and measure capacity, recovery objectives and backup security in the target environment.

Validation evidence

The validation results demonstrate exercised code paths and selected native file behaviours. They provide evidence for technical review, while full containment effectiveness, host compatibility and operational performance require testing in the intended environment.

348 automated tests passed

- Access, roles and tenant boundaries
- Detection, enrollment and incident workflows
- Delivery, retention and outage recovery
- Response workflows with mocked enforcement

7 native Windows file checks passed

- Disposable file-operation contract fixtures
- Pinned-handle relative rename behavior
- File-sharing and junction-race checks
- Full ACL and firewall workflows require staging

Automated tests and narrow native file checks do not establish live containment efficacy or production readiness.

Required staging validation

Deployment conditions determine whether security controls work as intended. Staging should verify identity, telemetry, permissions, enforcement and recovery together, including how containment behaves during service interruptions and host restarts.

Identity and host environment

- IdP issuance, token lifetime and revocation behavior
- PostgreSQL RLS with the deployed runtime role
- Windows Security/Sysmon and Linux audit collection
- Linux ClamAV installation, signatures and results

Enforcement and workload

- Cloudflare permissions, expiry and rule ordering
- ModSecurity / CRS tuning and real intervention
- Linux/Windows isolation, expiry and rollback
- False positives, overhead, backlog and recovery

Validate native Windows ACLs, firewall enforcement, scheduled-task expiry and reboot recovery before enabling containment.

Evaluating fit for your organisation

A suitable deployment starts with clear asset scope, accountable owners and measurable acceptance criteria. These decisions help teams assess coverage, operational impact, recovery expectations and the conditions under which approved response should be enabled.

Scope and ownership

- Select applications, APIs and server assets
- Identify incident owners and response approvers
- Define management-access exceptions
- Agree retention and recovery requirements

Acceptance criteria

- Measure detection coverage and false positives
- Verify roles and separate-actor approval
- Exercise containment, expiry and restoration
- Measure host overhead and service recovery

Production deployment requires environment-specific validation and an approved operating procedure.

Continuous monitoring deployment

The deployment adds a continuous monitoring dashboard, bounded host collectors, local source scanning and service templates. Health checks expose stale snapshots, while tenant-scoped access connects findings to operations. Deployment details and limits are documented in vulnsuite/README.md.

Monitoring and findings

- Minute-by-minute host snapshots
- Stale snapshot health checks
- Hourly scans of VulnSuite source
- Agent delivery health refresh

Deployment controls

- Dedicated PostgreSQL and Redis services
- Renewed tenant-scoped read tokens
- Systemd services and scheduled collectors
- Containment and external alerts disabled

Coverage depends on configured sources and targets; installed scanners do not imply active coverage.